HTTP Observatory Report

Report Feedback

Scan summary: magic-number.app

B+

↗ since last scan

Score: 80 / 100
Scan Time: Just now
Tests Passed: 9 / 10

Scan results

Scoring

Test	Score	Reason
Content Security Policy (CSP)	−20 ✕	Content Security Policy (CSP) implemented unsafely. This includes `'unsafe-inline'` or `data:` inside `script-src`, overly broad sources such as `https:` inside `object-src` c `script-src`, or not restricting the sources fc `object-src` or `script-src`.
Cookies	-	No cookies detected
Cross Origin Resource Sharing (CORS)	0 ✓	Content is not visible via cross-origin resource sharing (CORS) files or headers.
Redirection	0 ✓	All hosts redirected to are in the HTTP Strict Transport Security (HSTS) preload list.
Referrer Policy	0* ✓	`Referrer-Policy` header set to `no-referrer` `same-origin`, `strict-origin` or `strict-origin-when-cross-origin`.
Strict Transport Security (HSTS)	0* ✓	Preloaded via the HTTP Strict Transport Security (HSTS) preloading process.
Subresource Integrity	-	Subresource Integrity (SRI) not implemente but all scripts are loaded from a similar origin.
X-Content-Type-Options	0 ✓	`X-Content-Type-Options` header set to `nosniff`.

Test	Score	Reason
X-Frame-Options	0* ✓	**`X-Frame-Options`** (XFO) header set to **`SAMEORIGIN`** or **`DENY`**.
Cross Origin Resource Policy	-	Cross Origin Resource Policy (CORP) is not implemented (defaults to **`cross-origin`**).

* Normally awards bonus points, however, in this case they are not included in the overall score (find out why).

CSP analysis

✗ Content Security Policy (CSP) implemented unsafely. This includes **`'unsafe-inline'`** or **`data:`** inside **`script-src`**, overly broad sources such as **`https:`** inside **`object-src`** or **`script-src`**, or not restricting the sources for **`object-src`** or **`script-src`**.

Test	Result	
Blocks execution of inline JavaScript by not allowing **`'unsafe-inline'`** inside **`script-src`**	✗	Blocking the exec strongest protecti Moving JavaScrip site more maintair
Blocks execution of JavaScript's **`eval()`** function by not allowing **`'unsafe-eval'`** inside **`script-src`**	✓	Blocking the use prevent the execu
Blocks execution of plug-ins, using **`object-src`** restrictions	✓	Blocking the exec as inherited from loading Flash or J
Blocks inline styles by not allowing **`'unsafe-inline'`** inside **`style-src`**	✗	Blocking inline sty modifying the cor styles to external more maintainabl
Blocks loading of active content over HTTP or FTP	✓	Loading JavaScri to execute arbitra policy and changi
Blocks loading of passive content over HTTP or FTP	✓	This site's Conten passive content s protocols such as load them over H
Clickjacking protection, using **`frame-ancestors`**	✗	The use of CSP's grained control ov
Deny by default, using **`default-src 'none'`**	✗	Denying by defau your Content Sec resources you did

Test	Result	
Restricts use of the `<base>` tag by using `base-uri 'none'`, `base-uri 'self'`, or specific origins.	✕	The `<base>` tag ca scripts from untru
Restricts where `<form>` contents may be submitted by using `form-action 'none'`, `form-action 'self'`, or specific URIs	✕	Malicious JavaSc sensitive form dat for data exfiltratio
Uses CSP3's `'strict-dynamic'` directive to allow dynamic script loading (optional)	-	`'strict-dynamic` load all your site's track `script-src`

Cookies

No cookies detected

Raw server headers

Header	Valu
Age	0
Date	Wed, 01 Apr 2026 12:58:17 GMT
Etag	"ca0130efb2cc6e2d90a6295345209a6f-ssl-df
Vary	Accept-Encoding
Server	Netlify
Connection	close
Cache-Status	"Netlify Edge"; fwd=miss
Content-Type	text/html; charset=UTF-8
Accept-Ranges	bytes
Cache-Control	public,max-age=0,must-revalidate
Referrer-Policy	strict-origin-when-cross-origin
X-Frame-Options	DENY
X-Nf-Request-Id	01KN4HZ3CD6C5PM2CCZ6478A7K
Transfer-Encoding	chunked
Permissions-Policy	camera=(), microphone=(), geolocation=()
X-Content-Type-Options	nosniff
Content-Security-Policy	default-src 'self'; script-src 'self' 'unsafe-inline https://fonts.googleapis.com; font-src 'self' htt

Header	Valu
	connect-src 'self'
Strict-Transport-Security	max-age=31536000

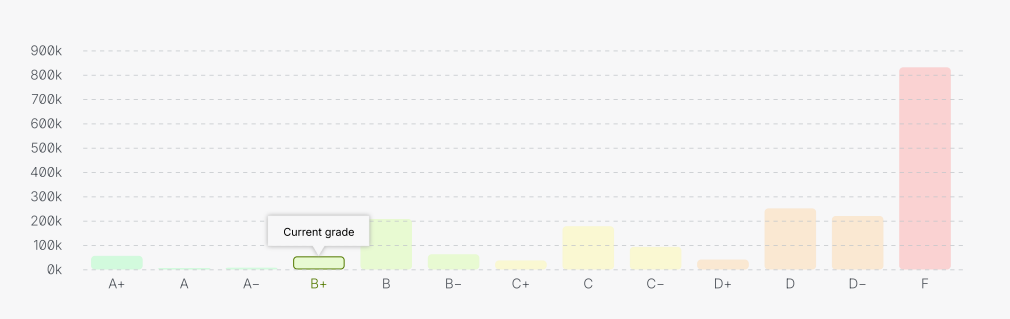
Scan history

Changes in score over time

Date	
1 abr 2026, 9:58:17	80
28 mar 2026, 17:31:08	50

Benchmark comparison

Performance trends from the past year



Refer to this graph to assess the website's current status. By following the recommendations provided and rescanning, you can expect an improvement in the website's grade.